FUTURE_CS_01

Web Application Security Assessment

Target: testphp.vulnweb.com
Tools Used: Nmap & OWASP ZAP

Prepared By: Shradha Dubey
Date: 03 March 2026

#Objective:

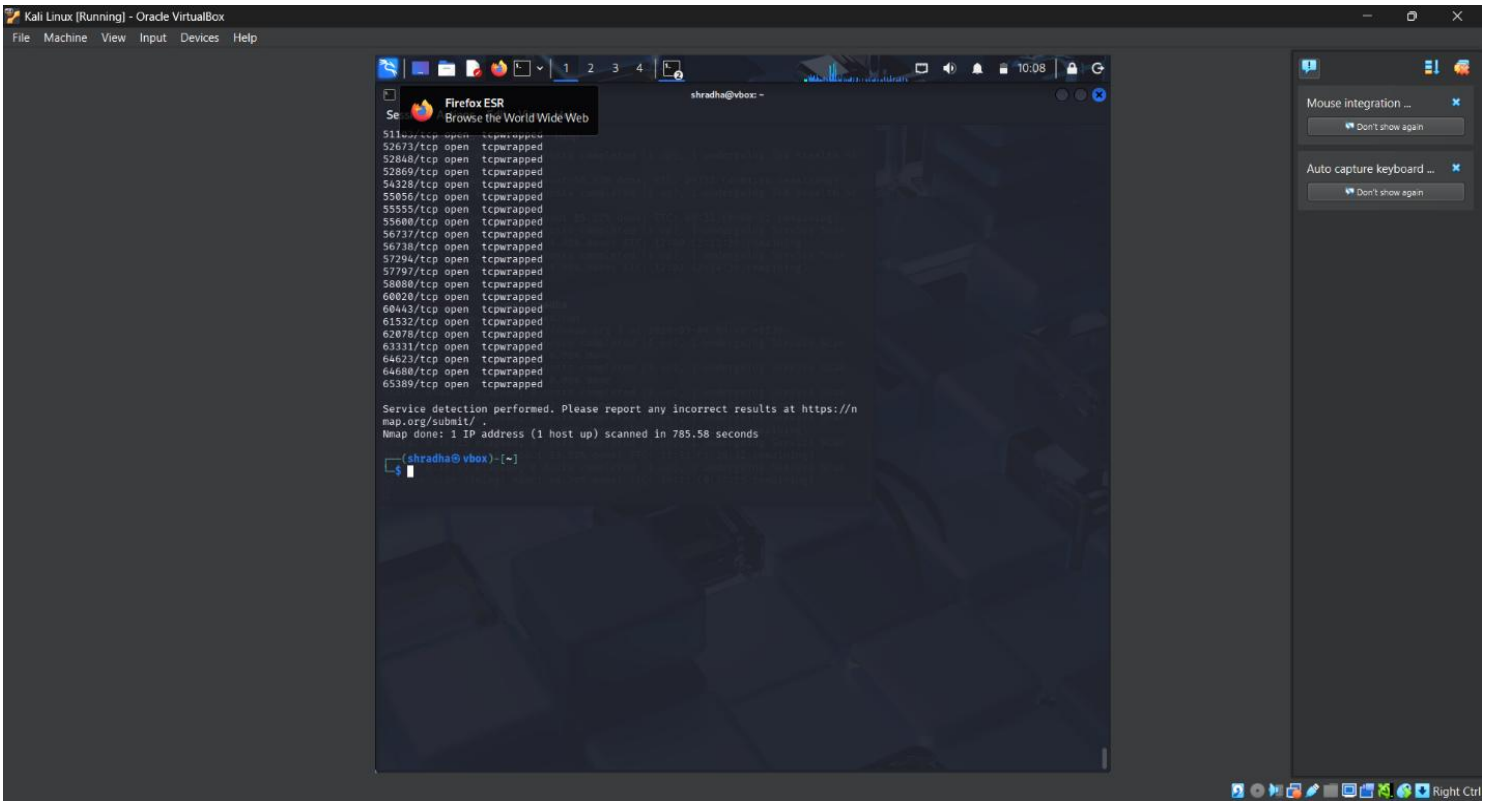
This assessment was conducted to identify security vulnerabilities in an intentionally vulnerable web application using automated scanning techniques.

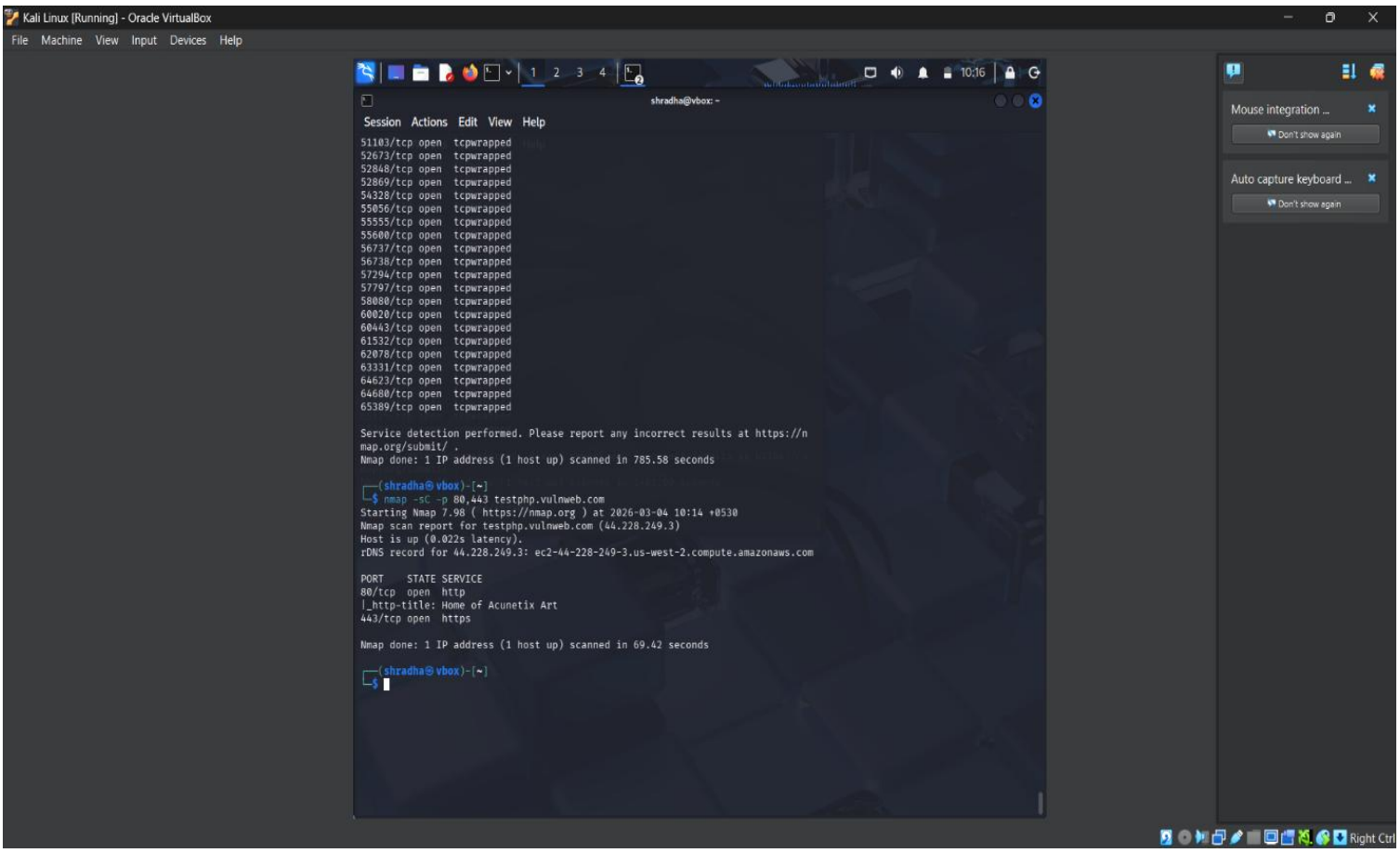
#Tools Used

- Nmap (Service & Version Detection)
- OWASP ZAP (Passive & Active Scanning)

#Network Reconnaissance (Nmap)

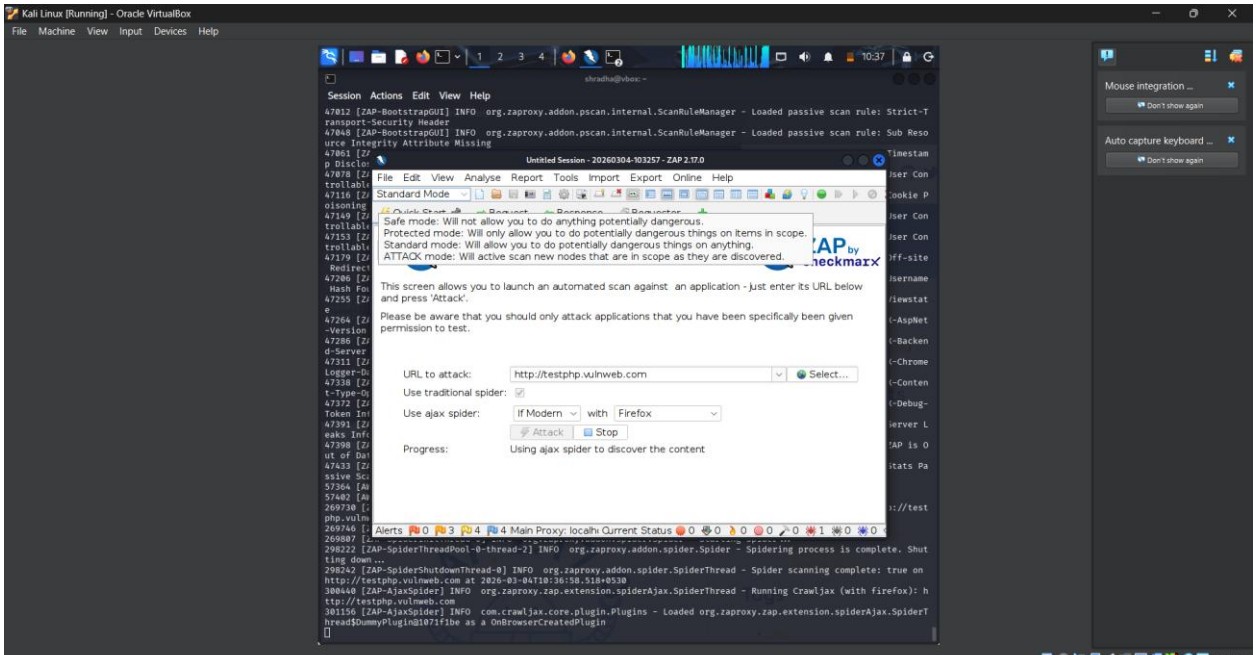
- Command : nmap -sV -sC -p- testphp.vulnweb.com
- Nmap was used to identify open ports and running services on the target system.

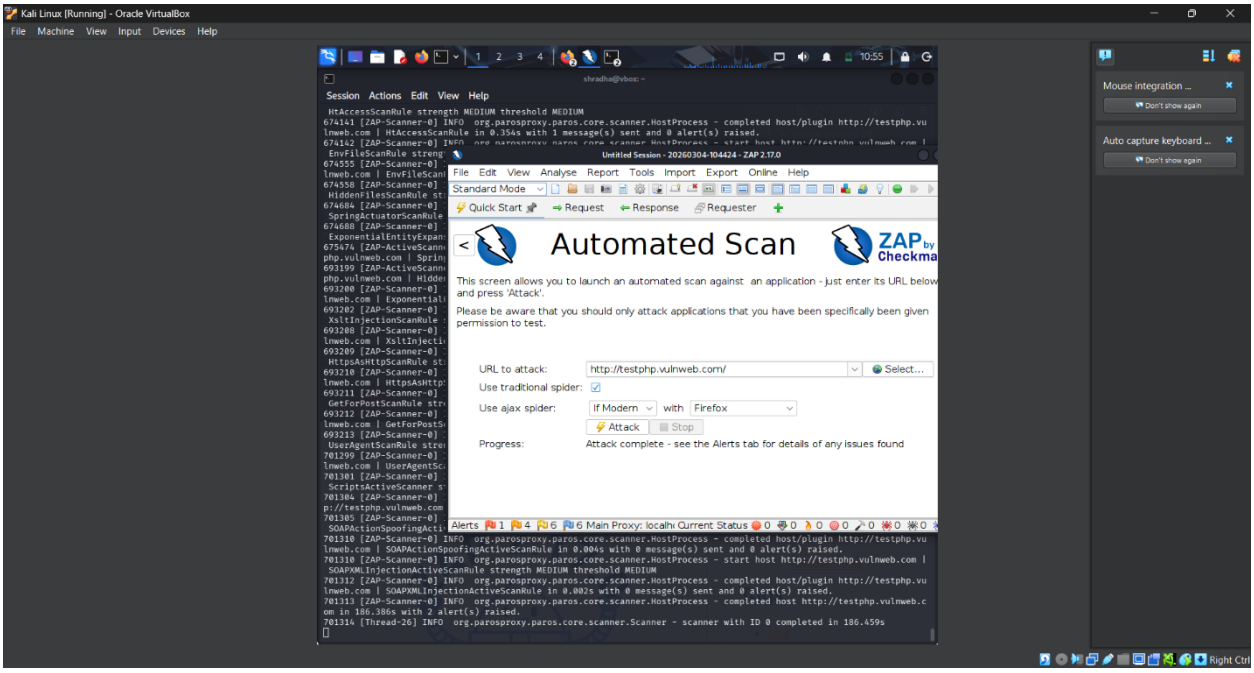




#OWASP ZAP Automated Scan

OWASP ZAP was used to perform an automated vulnerability scan against the target application.



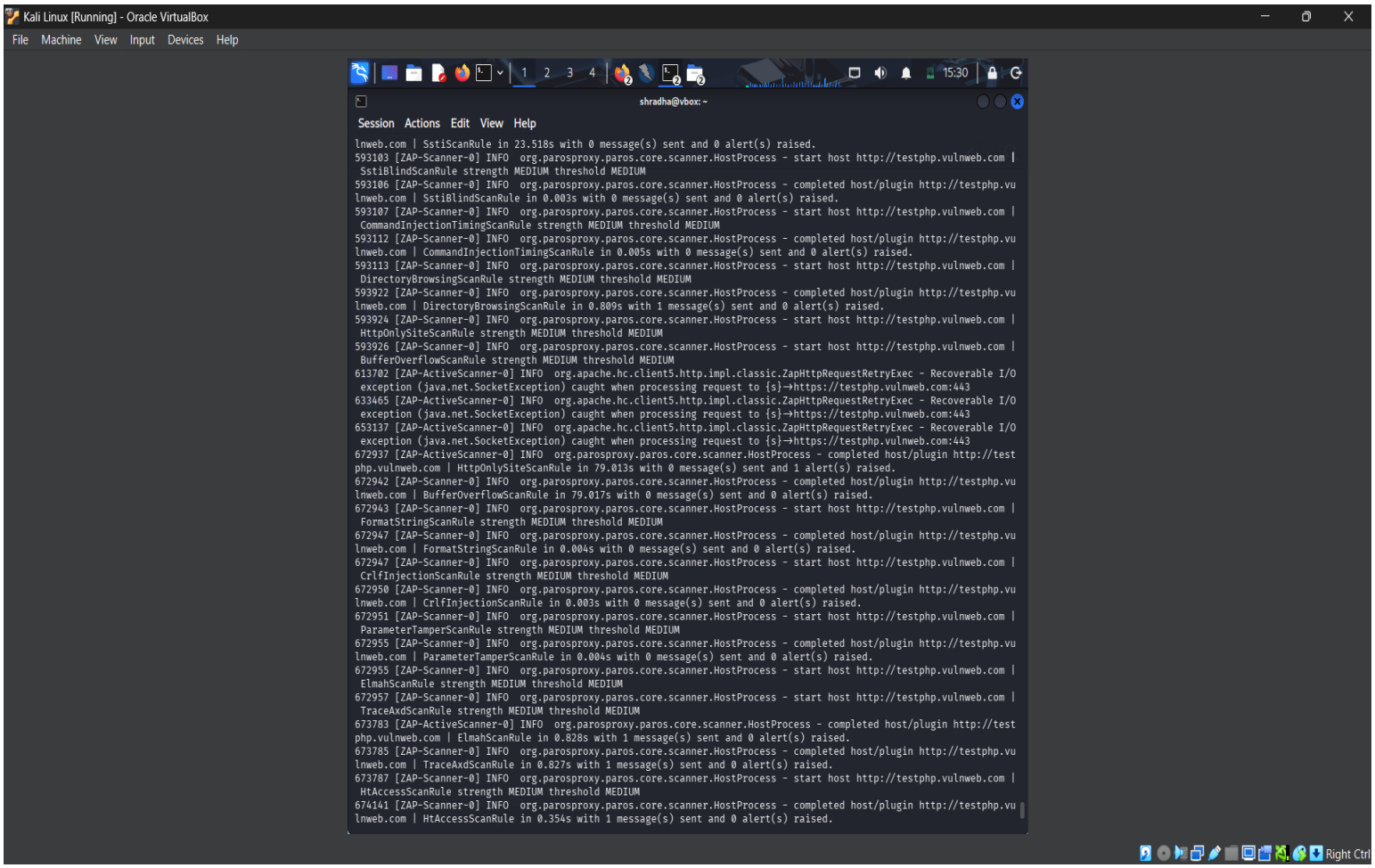


#Alert Summary

Table:

Risk Level	Count
High	1
Medium	3
Low	4
Informational	4

Total: 12 Alerts



✓ **High Risk Vulnerability**

- Cross-Site Scripting (DOM-Based)

  Risk Level: High
  Confidence: High
  Affected URL:
  http://testphp.vulnweb.com

- Description:

  A DOM-based Cross-Site Scripting (XSS) vulnerability was identified. This vulnerability allows client-side script execution by manipulating the Document

Object Model (DOM) environment in the victim's browser.

✓ **Medium Risk Vulnerabilities**

1. Content Security Policy (CSP) Header Not Set

   Risk Level: Medium
   Confidence: High

   Description:

   The application does not define a Content Security Policy (CSP), increasing the risk of XSS attacks.

2. HTTP Only Site

   Risk Level: Medium
   Confidence: Medium

   Description:

   The application allows communication over HTTP, which is not encrypted.

- 3. Anti-Clickjacking Header

  Risk Level: Medium

  Description:

  The application does not implement the X-Frame-Options or equivalent protection.

✓ **Low Risk Vulnerabilities :**

The following low-risk issues were identified:

- Server Version Information Disclosure
- X-Powered-By Header Exposure
- Missing X-Content-Type-Options Header
- In-Page Information Disclosure
- Strict-Transport-Security Header Not Set

<u>Informational Findings</u>

The scan also identified informational findings such as:

- Cache-related configurations
- Authentication request identification
- Charset mismatch warnings
- Modern web application detection

These findings do not directly indicate vulnerabilities but provide contextual security information.